Account Takeover via Token-less Password Reset

1. Report Title: Unauthenticated Account Takeover through Unverified Password Reset

2. Finding ID: ELMS-002

3. Vulnerability Name: Password reset without identity proof (no email link / OTP / token)

4. Executive Summary

The "Emp Password Recovery" page lets anyone set a new password for an account after supplying only the target's **Employee ID** and **email address** — both of which are non-secret and are disclosed elsewhere in the app (ELMS-001, ELMS-003). There is no emailed reset link, one-time code, security question, or token. Knowing the two identifiers is sufficient to take over the account.

5. Severity

High

6. CVSS 4.0

`CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N` ? Base **?9.3 (Critical)** once the identifiers are known. Rated **High** overall to reflect the precondition that the attacker must first obtain a valid (EmpId, email) pair — which ELMS-001/ELMS-003 make trivial.

7. OWASP Classification

A07:2021 – Identification and Authentication Failures (also A01 Broken Access Control).

8. CWE Classification

CWE-640 (Weak Password Recovery Mechanism); CWE-620 (Unverified Password Change); CWE-287 (Improper Authentication).

9. Affected URL

`http://localhost/elms/forgot-password.php`

10. Affected Parameter

Stage 1: `empid` , `emailid` . Stage 2: `newpassword` , `confirmpassword` , `change` .

11. Authentication Requirements

None. Fully unauthenticated.

12. Affected User Roles

All employees (the admin uses a separate flow). Any employee account can be taken over.

13. Vulnerability Description

`forgot-password.php` performs `SELECT id FROM tblemployees WHERE EmailId=:email AND EmpId=:empid` . If a row matches, it stores `$_SESSION['empid']` and immediately renders a "change your password" form. Submitting that form runs `UPDATE tblemployees SET Password=:newpassword WHERE id=:empid` using the session value. No secret, emailed token, or OTP is ever required — possession of the (EmpId, email) pair alone authorises the password change.

14. Technical Root Cause

The recovery design conflates "knowing two public identifiers" with "proving control of the account." A secure reset must require a secret delivered out-of-band (email/SMS link or code) that the requester cannot otherwise obtain.

15. Preconditions

A valid `(EmpId, EmailId)` pair for the victim. These are exposed by ELMS-001 (IDOR shows EmpId + email of any employee) and ELMS-003 (the DB dump lists all of them), and EmpIds are short numeric strings.

16. Proof of Concept

Submitting the known test pair `empid=7856214` + `emailid=jhn12@gmail.com` (John) returns the authenticated-less "change your password" form with `newpassword` / `change` fields — i.e., the reset is authorised with no verification step. **The actual password change was deliberately NOT executed** to preserve the lab account/DB; the vulnerability is proven at the point the change form is served for an unauthenticated requester. A wrong email returns "Invalid details" (also an enumeration oracle, ELMS-010).

17. Reproduction Steps

1. Browse to `http://localhost/elms/forgot-password.php` (no login).
2. Submit `empid=7856214` , `emailid=jhn12@gmail.com` , `submit=Reset` .
3. Observe the response now contains the **"change your password"** form (`name="newpassword"` , button `name="change"`) — no email/OTP was required.
4. (Not performed, to avoid modifying data) Submitting `newpassword` + `confirmpassword` + `change` would set the victim's password; the attacker then logs in at `index.php` .
5. Control: repeat step 2 with `emailid=wrong@nope.com` ? response is "Invalid details" (no reset form).

18. HTTP Request Evidence

```
POST /elms/forgot-password.php HTTP/1.1
Host: localhost
Content-Type: application/x-www-form-urlencoded

empid=7856214&emailid=jhn12@gmail.com&submit=Reset
```

Evidence: `.../evidence/09_reset_valid.resp` (valid pair) and `09_reset_invalid.resp` (wrong email).

19. HTTP Response Evidence

Valid pair (markers extracted):

```
change your password
<input ... name="newpassword" ...>
<button ... name="change" ...>Change</button>
```

Wrong email:

```
ERROR : Invalid details
```

20. Screenshots

Not captured (headless env; Playwright unavailable — blocked, not fabricated). HTTP evidence above is authoritative.

21. Security Impact

Complete takeover of any employee account by an unauthenticated attacker who knows two public identifiers: read/modify the victim's profile and leave data, apply/alter leave in their name, and pivot. Combined with ELMS-001 (harvest all pairs) this becomes **mass** account takeover.

22. Exploitation Feasibility

High. No authentication, no tooling beyond a browser/curl, and the required identifiers are disclosed by other confirmed findings or are short/guessable.

23. Existing CVE Verification

No matching CVE for this product/flaw (verified against NVD/vendor). CVE-2021-43451 exists for the *Employee Record Management System* `forgetpassword.php` but it is **SQL injection in a different product** — **not**

applicable here (this reset is parameterized; the defect is the missing verification step). Status: **No matching CVE identified** (potentially novel; vendor coordination recommended).

24. References

- OWASP WSTG-ATHN-09 (Weak Password Change/Reset); OWASP A07:2021; CWE-640; NIST SP 800-63B §5.1.1 (reset secrets).

25. Remediation

Require an out-of-band secret for reset: generate a cryptographically random, single-use, time-limited token, store its hash, email it to the registered address, and only allow the password change when the valid unexpired token is presented. Do not reveal whether an identity matched. Invalidate existing sessions on reset. Remove the "set password directly after lookup" behaviour.

26. Recommended Secure Code Example

```
// Request stage: never reveal match/no-match
$token = bin2hex(random_bytes(32));
$dbh->prepare("UPDATE tblemployees SET ResetTokenHash=:h, ResetExpires=:e
               WHERE EmailId=:email")->execute([
  ':h'=>hash('sha256',$token), ':e'=>date('Y-m-d H:i:s', time()+1800), ':email'=>$email]);
mail($email, "Password reset", "https://host/elms/reset.php?token=$token"); // out-of-band
echo "If the account exists, a reset link has been sent.";

// Reset stage: validate token, then set password
$row = /* fetch by hash('sha256',$_GET['token']) AND ResetExpires > now() */;
if (!$row) { exit('Invalid or expired link'); }
$dbh->prepare("UPDATE tblemployees SET Password=:p, ResetTokenHash=NULL WHERE id=:id")
    ->execute([':p'=>password_hash($_POST['newpassword'], PASSWORD_DEFAULT), ':id'=>$row->id]);
```

27. Retest Procedure

Attempt a reset with a valid (EmpId, email) pair. Fixed behaviour: no password-change form is shown; only a generic "a link has been sent" message appears, and the password can be changed only via a valid emailed token.

28. Final Conclusion

Confirmed unauthenticated, token-less password reset leading to account takeover, demonstrated non-destructively up to the change form. High severity and the second half of the mass-ATO chain. Fix by introducing out-of-band token verification.